E-COMMERCE · PRESENTATION 2 · WEEK 7

Bloom & Grind

Specification and working prototype

github.com/Proximito/Bloom-and-Grind · tag P2

Avram Eliana · Ferraglio Danut

Group CEN4.H A

REQUIREMENTS · 1 OF 2

From finding a product to paying for it

Requirement	How we implement it	Owner
A1 Catalog	Pages /products (24 per page, Prisma skip/take), /category/[slug] and /product/[slug] with name, description, price, images and stock label.	Avram Eliana
A2 Search	Header search: case-insensitive match on product names (Prisma contains); no hits shows “No products match …” and a link back to the catalog.	Avram Eliana
A3 Cart	Cart and items live in the database per customer, so they survive logout; every change recomputes the total from DB prices and rejects qty above stock.	Avram Eliana
A4 Accounts	Register and log in with Auth.js credentials; passwords hashed with bcrypt (cost 12). Customers save delivery addresses and pick a default.	Ferraglio Danut
A5 Checkout	Address → delivery (courier 20 lei or locker 12 lei) → summary with server totals → Stripe payment; confirmation shows the order number.	Ferraglio Danut
A6 Payment	Order starts NEW (unpaid). Only the signed Stripe webhook sets PAID; the redirect page just reads status. A declined card leaves it unpaid.	Ferraglio Danut

REQUIREMENTS · 2 OF 2

After the payment, and around everything

Requirement	How we implement it	Owner
A7 Stock	The webhook transaction runs stock = stock - qty WHERE stock ≥ qty, so the last unit sells only once; cancelling a paid order restores stock.	Ferraglio Danut
A8 Order history	My orders: number, date, total and status, plus a detail page with products; every query is filtered by the logged-in user's id.	Avram Eliana
A9 Admin panel	Our own /admin for role ADMIN: product and category CRUD with image upload; orders filtered by status, Paid → Shipped → Delivered or Cancelled.	Avram Eliana
A10 Security	Zod on every input, Prisma for all queries; middleware answers 403 on /admin and /api/admin for non-admins and rejects cross-origin writes (CSRF).	Ferraglio Danut
A11 Responsive	Tailwind mobile-first layouts checked at 360 px: catalog grid goes 1 → 2 → 4 columns; cart and checkout stack in one column.	Avram Eliana
A12 Tests	Vitest, one command (npm test), 12+ tests: cart limits, totals with delivery, webhook paid / repeated / declined, last-unit race, admin 403.	Ferraglio Danut

BONUS FEATURES

Four bonuses, two each

18 pts

B1 · Filtered search

5 pts · Eliana

Category, price range, in-stock and brew-method filters, sort by price or newest, all kept in the URL.

B2 · Recommendations

4 pts · Danut

“Frequently bought together” from paid orders; falls back to same category plus shared brew methods.

B3 · Reviews

4 pts · Eliana

Only buyers with a paid order for the product can rate it 1–5; average on product cards; admin can hide a review.

B6 · Order email

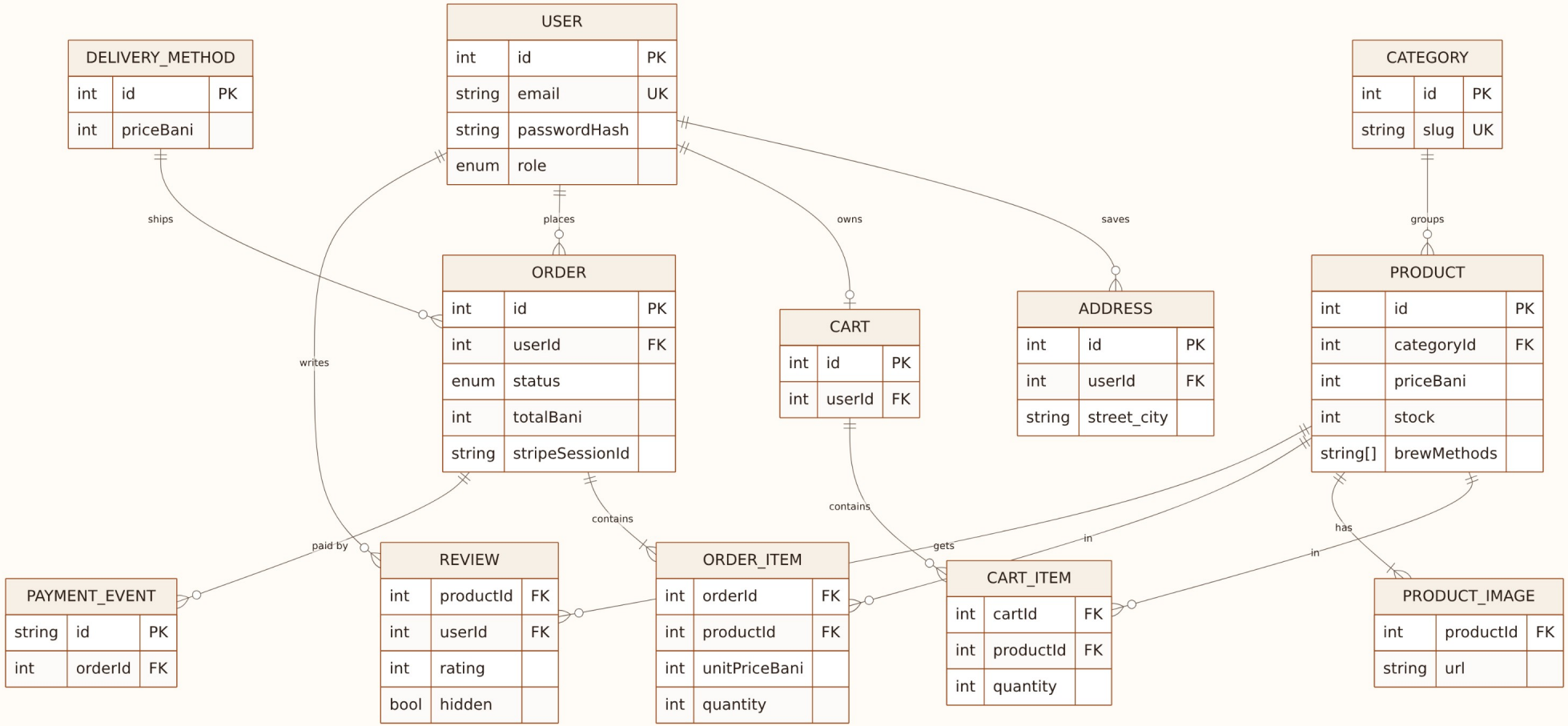
5 pts · Danut

When the webhook marks an order Paid, Nodemailer sends the confirmation to our Mailtrap sandbox inbox.

DATA MODEL

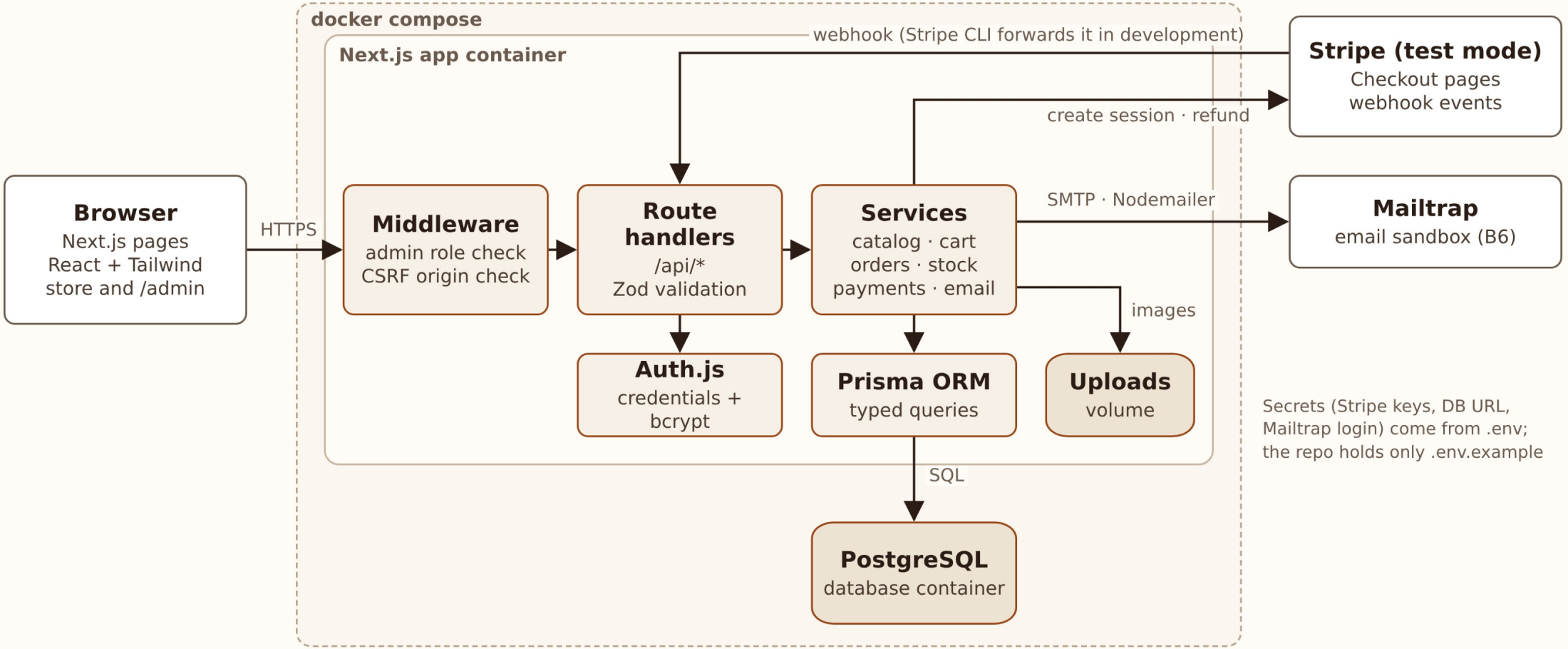
12 tables in PostgreSQL

Key columns shown; full columns in the specification.
Prices are whole bani (1 leu = 100 bani).



ARCHITECTURE

One Next.js app, one database, two outside services



API ENDPOINTS · 1 OF 2

Catalog, accounts and cart

Method	Route	Access	Covers
GET	/api/products?page&q&category&sort…	Public	A1 A2 B1
GET	/api/products/[slug]	Public	A1
GET	/api/categories	Public	A1
GET	/api/products/[id]/recommendations	Public	B2
GET, POST	/api/products/[id]/reviews	Public / buyer	B3
POST	/api/auth/register	Public	A4
POST	/api/auth/[…nextauth]	Public (login, logout)	A4
GET, POST	/api/account/addresses	Customer	A4
PUT, DELETE	/api/account/addresses/[id]	Owner only	A4
GET	/api/cart	Customer	A3
POST, PATCH, DELETE	/api/cart/items[/productId]	Customer	A3

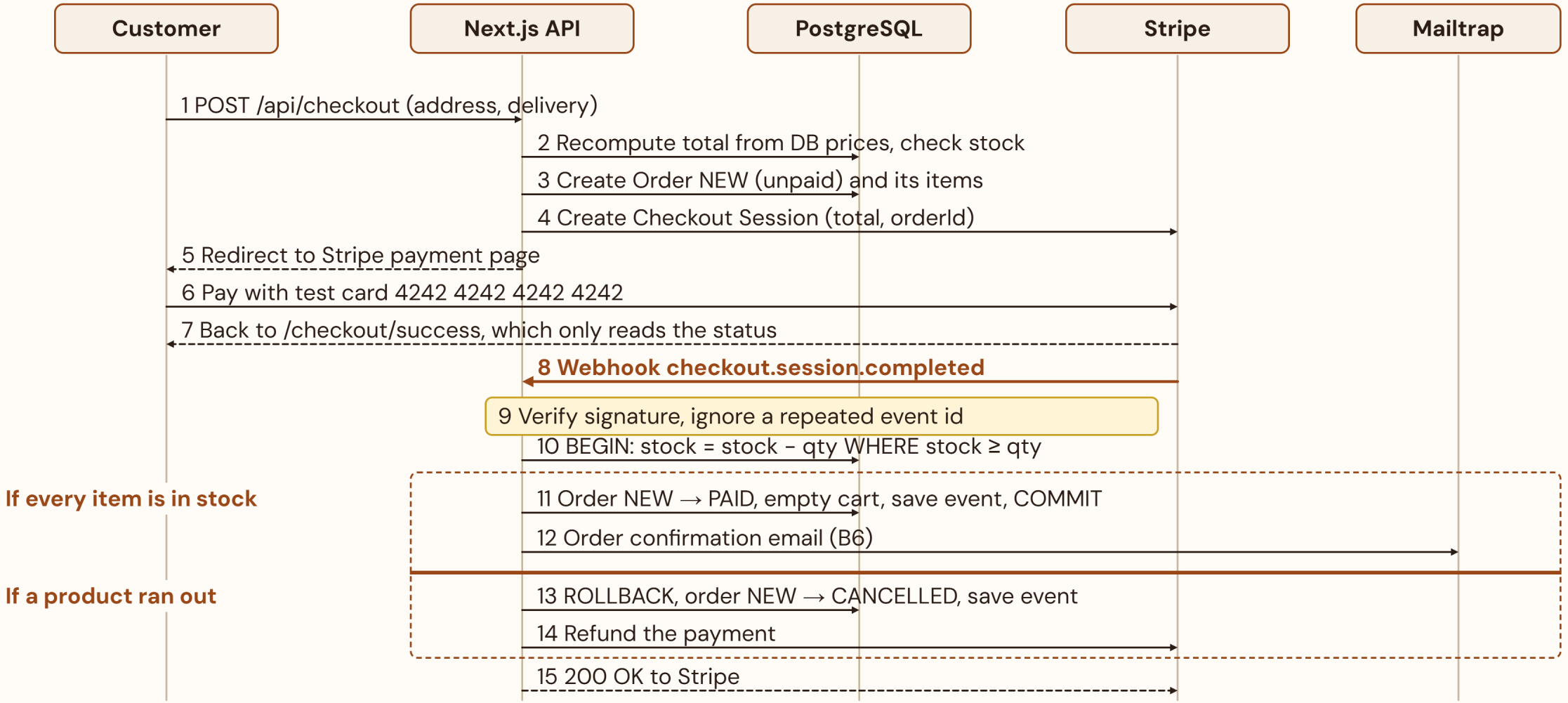
API ENDPOINTS · 2 OF 2

Checkout, payment and administration

Method	Route	Access	Covers
GET	/api/delivery-methods	Public	A5
POST	/api/checkout	Customer	A5 A6
GET	/api/orders	Customer (own)	A8
GET	/api/orders/[id]	Owner or admin	A8
POST	/api/webhooks/stripe	Stripe signature	A6 A7 B6
GET, POST	/api/admin/products	Admin	A9
PUT, DELETE	/api/admin/products/[id]	Admin	A9
POST	/api/admin/uploads	Admin	A9
GET, POST	/api/admin/categories	Admin	A9
PUT, DELETE	/api/admin/categories/[id]	Admin	A9
GET	/api/admin/orders?status=	Admin	A9
PATCH	/api/admin/orders/[id]/status	Admin	A7 A9
PATCH	/api/admin/reviews/[id]	Admin (hide)	B3

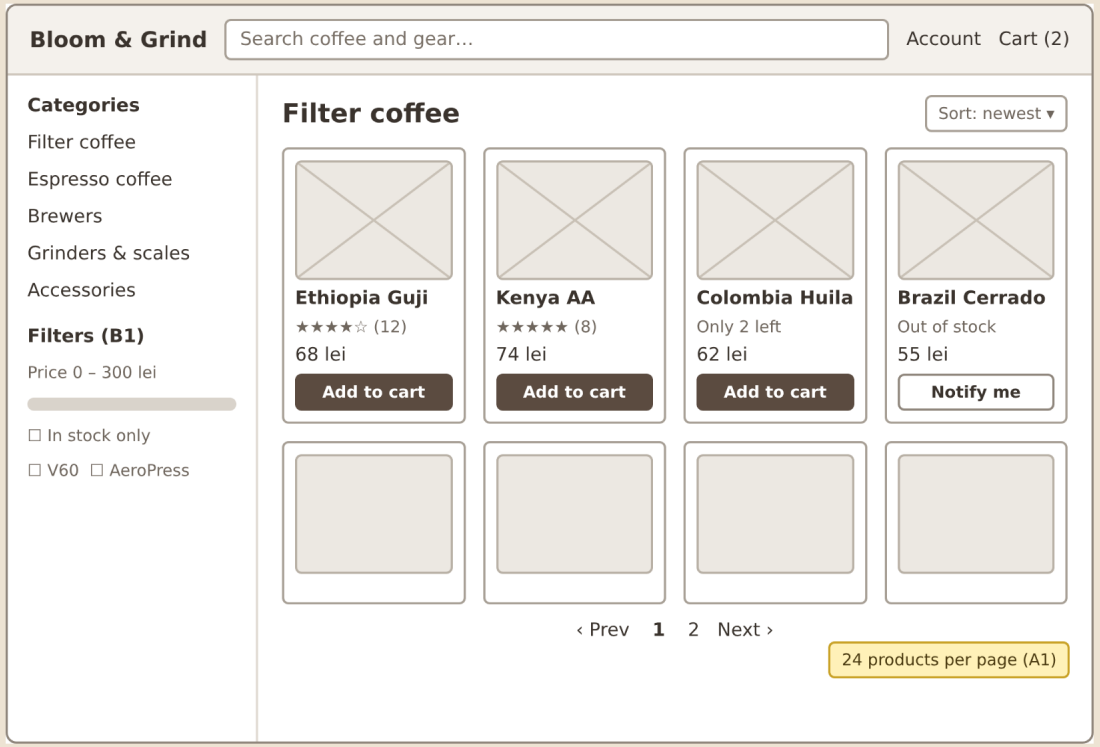
Payment flow, step by step

Declined card 4000 0000 0000 0002: no completed event arrives, so the order stays NEW (unpaid).



WIREFRAMES · 1 OF 3

Catalog and product page



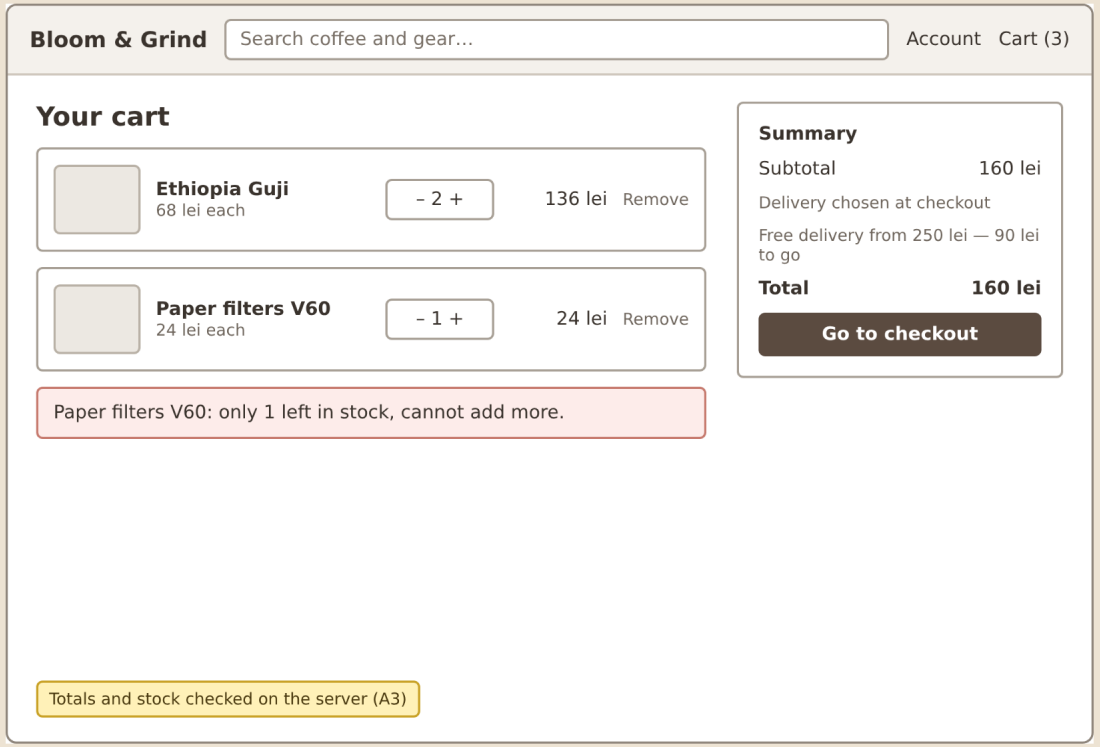
Catalog: categories, filters (B1), 4-column grid, 24 per page



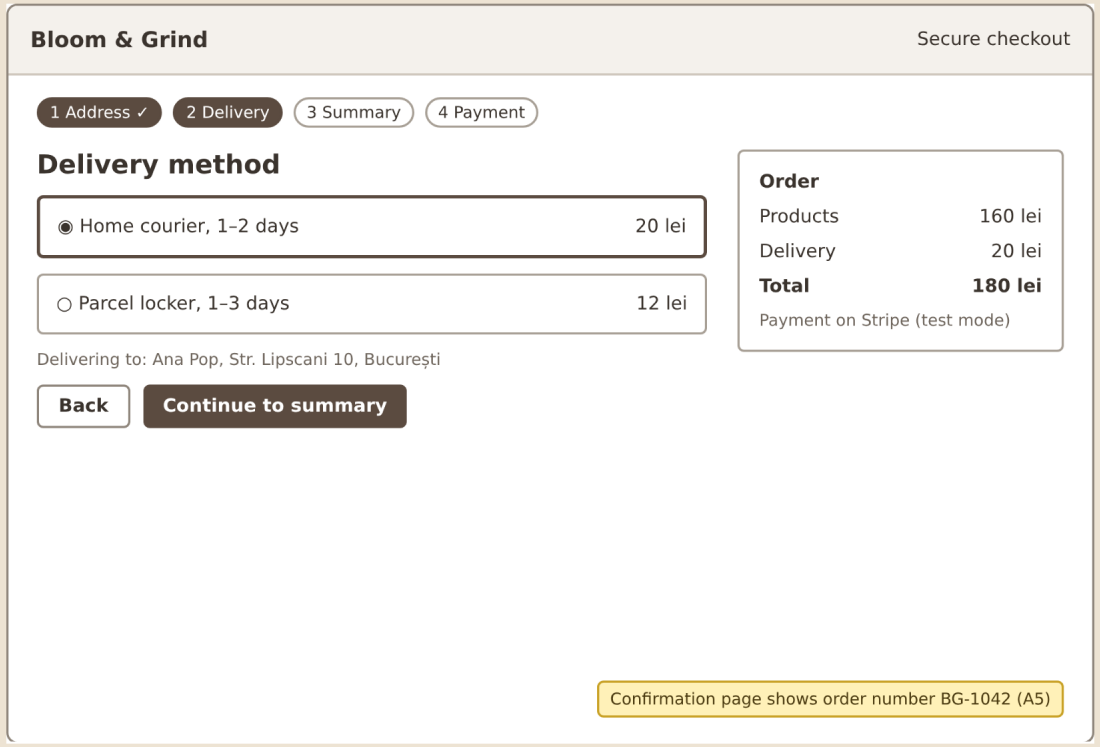
Product: gallery, stock label, quantity, recommendations (B2)

WIREFRAMES · 2 OF 3

Cart and checkout



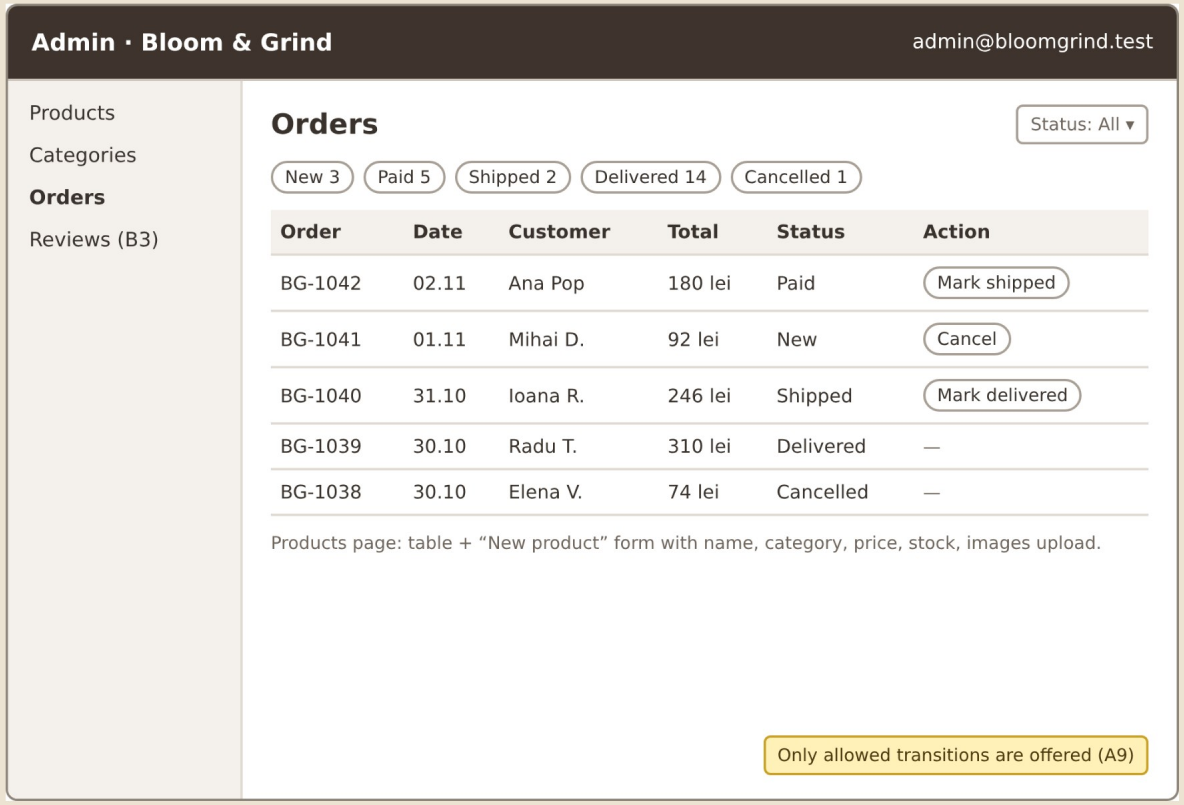
Cart: quantities, server-side stock limit, free delivery from 250 lei



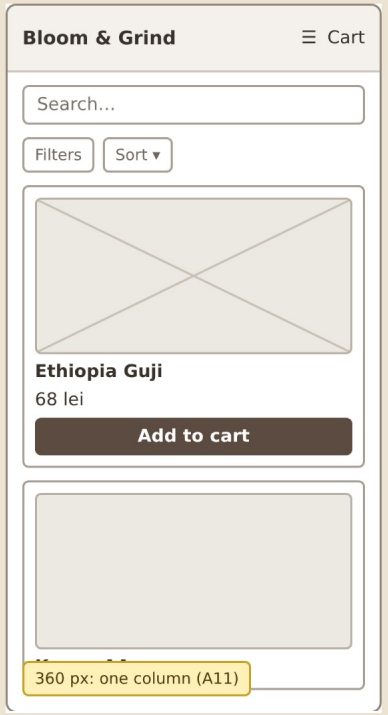
Checkout step 2: two delivery methods with different costs

WIREFRAMES · 3 OF 3

Administration panel and phone view



Admin orders: status filter, only allowed next steps



Catalog at 360 px (A11)

Admin also has

Products: table and form with category, price, stock and image upload

Categories: name and slug

Reviews: hide or show (B3)

WORKING PROTOTYPE · LIVE

Catalog from the database, and login

1 docker compose up starts the app and PostgreSQL; the seed loads 35 products in 5 categories

2 /products: page 1 and 2, a category page, a product page, a search with no results

3 Register a new customer, log out, log back in

4 As a customer, /admin answers 403; as admin, the panel opens

Test accounts (in README)

customer@bloomgrind.test

admin@bloomgrind.test

Commit tagged **P2** on github.com/Proximito/Bloom-and-Grind

PLAN TO P3

Same split, five weeks of building

Week	Avram Eliana	Ferraglio Danut
8	A3 cart, A9 products and categories	A5 checkout steps, addresses
9	A9 orders and status changes	A6 webhook, A7 stock
10	A8 order history, A11 at 360 px	A10 security pass, A12 tests
11	B1 filters, B3 reviews	B2 recommendations, B6 email
P3	Rehearse demo, backup video	Final README, test run

Changed since P1

Added Nodemailer with Mailtrap for B6. Auth.js keeps the session in an encrypted httpOnly cookie; the role is checked on the server.

P1 feedback

[What the teachers asked] → [what we changed]

FOR APPROVAL

Questions?

We ask to freeze A1–A12 as specified, plus bonuses B1, B2, B3 and B6

Specification PDF · repository tag P2

Avram Eliana · Ferraglio Danut